Escenarios de malware (Módulo 2 - Clase 1)

Escenario 1: El "Anfitrión" Silencioso en la Administración Pública

Contexto: Sofía trabaja en el área administrativa de una dependencia estatal en Montevideo. Su computadora contiene archivos críticos: registros de asistencia, resoluciones firmadas y planillas de presupuesto.

El Incidente: Sofía recibe un correo electrónico de un remitente que parece ser un proveedor habitual, con el asunto: "Factura Pendiente - Urgente". El correo contiene un archivo adjunto llamado `factura_mayo_2026.pdf.exe`. Sofía, bajo presión por el trabajo, hace doble clic. El sistema no parece abrir nada, pero el ventilador de la computadora comienza a girar ruidosamente.

Detalles Técnicos: El código malicioso ha comenzado a infectar todos los archivos `.doc` y `.pdf` locales, insertando su propio código en ellos. Además, utiliza el gestor de correo de Sofía para reenviar el mismo archivo a todos los contactos de la libreta de direcciones institucional.

Preguntas de Análisis Profundo:

1. **Taxonomía:** Explica por qué este malware se clasifica como un **Virus**. ¿Cuál es el "anfitrión" que necesita para sobrevivir y cómo se propagó?.
2. **Tríada CIA:** ¿Qué pilar se ve afectado cuando el malware modifica el código de otros archivos legítimos para replicarse?.
3. **Vulnerabilidad Humana:** Identifica la técnica de engaño utilizada. ¿Qué medida de "medida organizativa" (según Agesic) falló aquí?.
4. **Higiene Técnica:** Si Sofía hubiera tenido configurado el sistema para "mostrar extensiones de archivos conocidos", ¿cómo habría ayudado esto a detectar la amenaza?

1. Este malware se clasifica como un Virus debido a que tiene una dependencia con un archivo anfitrión, que en este caso es factura_mayo_2026.pdf.exe, además de que necesitó la intervención de Sofia.
2. El pilar que se ve afectado es el de la integridad de los datos y disponibilidad, debido a que se modifica el código original de los archivos para la programación del malware.
3. La técnica utilizada en este caso fue phishing, ya que se le envió a Sofía un correo que parecía ser legítimo de uno de los proveedores habituales de la empresa, el cual contenía un archivo malicioso que fue el que permitió al virus desplegarse en la máquina.
4. Si Sofía hubiera tenido la opción de mostrar extensiones ocultas se podría haber dado cuenta de que el archivo era un .exe en vez de un .pdf, de este modo se podría haber evitado la ejecución del malware en la máquina.

Escenario 2: El "Gusano" en la Red del Laboratorio de UTU

Contexto: El laboratorio de informática tiene 20 computadoras conectadas a un switch central. Todas corren una versión de Windows que no ha sido actualizada en seis meses por falta de tiempo del administrador.

El Incidente: Un estudiante conecta un pendrive infectado solo para copiar un PDF. Sin que el estudiante haga nada, una de las máquinas comienza a enviar miles de paquetes de red por segundo. En menos de 5 minutos, todas las computadoras del laboratorio están saturadas, internet deja de funcionar y el switch central se bloquea por el tráfico.

Detalles Técnicos: El malware explota una vulnerabilidad en el servicio de compartición de archivos (SMB). No requiere que ningún usuario haga clic; simplemente escanea la red local, encuentra otras IPs activas y se copia a sí mismo aprovechando el fallo del sistema operativo.

Preguntas de Análisis Profundo:

1. **Taxonomía:** ¿Por qué este comportamiento es característico de un **Gusano (Worm)** y no de un virus común?.
2. **Modelo de Capas (Stallings):** ¿En qué capas del modelo TCP/IP está operando esta amenaza para saturar el ancho de banda?.
3. **Gestión de Riesgos:** Identifica la **Vulnerabilidad** técnica y la **Amenaza** externa en este caso. ¿Cómo cambiaría el Riesgo si se hubieran aplicado los parches de seguridad?.
4. **Impacto en Activos:** ¿Cuál es el activo de hardware y cuál el de software que quedaron inoperativos?.

1. Porque no requiere intervención de una persona, el alumno puso el pendiente infectado y después el Worm se empezó a propagar.
2. En la capa de aplicación, luego en la de Transporte, después en la de internet y al final la de red

3. La vulnerabilidad técnica sería el sistema operativo sin actualizar hace meses, y la amenaza sería el alumno con el pendrive. Si el sistema operativo estuviera actualizado el riesgo sería muchísimo menor.
4. El activo de hardware sería el switch central y el de software sería el Internet

Escenario 3: El "Regalo" de la Herramienta Gratuita

Contexto: Un estudiante de bachillerato necesita un software para editar videos para un proyecto final. Encuentra una web que ofrece "Adobe Premiere Pro 2026 - Full Gratis" en un archivo `.zip`.

El Incidente: El estudiante descarga e instala el programa. El editor de video funciona perfectamente y no muestra errores. Sin embargo, en segundo plano, el instalador agregó un archivo llamado `system_driver.dll` que se inicia con Windows. Tres días después, el estudiante nota que alguien cambió la contraseña de su Instagram y que hay movimientos extraños en su cuenta bancaria.

Detalles Técnicos: El programa legítimo actuó como un "Caballo de Troya". El archivo oculto es en realidad un *keylogger* que captura cada pulsación del teclado y la envía a un servidor externo mediante el protocolo HTTP.

Preguntas de Análisis Profundo:

1. **Taxonomía:** ¿Por qué se define este ataque como un **Troyano**? ¿Cuál es la diferencia clave entre este y el Gusano del escenario anterior?.
2. **Wireshark Connection:** Si hubieras estado analizando el tráfico con Wireshark mientras el estudiante usaba el programa, ¿qué filtros de visualización o funciones (como "Follow Stream") te habrían permitido ver las contraseñas viajando hacia el atacante?.
3. **Tríada CIA:** ¿Qué pilar es el que se rompe cuando el atacante logra leer las credenciales del usuario sin ser detectado?.
4. **Ética:** ¿Es responsable el sitio web que aloja el software "crackeado" o es responsabilidad exclusiva del usuario por no usar fuentes oficiales? Vincula esto con la definición de Ciudadanía Digital.

1. Este malware se define como troyano debido a que se presenta como una aplicación legítima de edición de videos, mientras que de fondo ejecuta un programa malicioso (en este caso un Keylogger) que se encarga de robar datos de la máquina. La principal diferencia entre el Troyano y los Worms es que el primero necesita la intervención de una persona para que actúe,

mientras que el Worms tiene la capacidad de propagarse sin intervención humana.

2. La función Follow Stream reconstruye la conversación completa entre la computadora y el servidor del atacante, permitiendo identificar qué tipos de datos se están enviando al servidor desde la máquina.
3. En este caso se vulnera el pilar de la confidencialidad, debido a que un externo puede leer los datos del usuario a pesar de no tener autorización.
4. Responsabilidad del sitio web: Alojar software "crackeado" o pirateado es una actividad ilegal que, además, suele actuar como un vector de distribución de malware. Los administradores del sitio tienen una responsabilidad ética y legal directa por distribuir herramientas dañinas y lucrar o perjudicar a los usuarios a través del engaño.

   Responsabilidad del usuario: El estudiante cometió una imprudencia al ignorar las medidas básicas de seguridad. En internet, "cuando el producto es gratis y normalmente es de pago, el producto eres tú (o tus datos)".

Escenario 4: Secuestro en el Sector Salud

Contexto: Una mutualista privada en Uruguay maneja las historias clínicas electrónicas de 50.000 pacientes.

El Incidente: Un lunes por la mañana, los médicos no pueden abrir las fichas de los pacientes. En todas las pantallas aparece un fondo negro con un texto en rojo que dice: "Sus archivos han sido cifrados. Tienen 48 horas para pagar 2 BTC o los datos serán borrados y publicados en internet".

Detalles Técnicos: Se trata de una variante de Ransomware que ingresó a través de una credencial de acceso remoto (RDP) débil. El malware utilizó cifrado asimétrico para bloquear el acceso a la base de datos SQL del hospital.

Preguntas de Análisis Profundo:

1. **Tríada CIA:** Este es un ataque total a la **Disponibilidad**. Explica cómo esta falta de acceso puede poner en riesgo la vida de las personas (activo "Personas").
2. **Marco Normativo (Ley 18.331):** Las historias clínicas contienen **Datos Sensibles**. Según la ley uruguaya, ¿qué responsabilidad tiene la mutualista ante la posible filtración de esta información?.
3. **Respuesta a Incidentes:** Agesic recomienda **no pagar**. ¿Qué medidas de "Defensa en Profundidad" (como backups) deberían haber estado funcionando para evitar el pago?.
4. **Análisis de Impacto:** Calcula el riesgo utilizando la fórmula $Riesgo = Impacto \times Probabilidad$ para este escenario específico.

1. La pérdida de disponibilidad provoca que, sin acceso a la base de datos, el personal médico pierde visibilidad sobre historiales de alergias, medicamentos recetados, tipos de sangre y patologías crónicas. Administrar un fármaco contraindicado a un paciente en urgencias, transfundir sangre incompatible o retrasar una intervención quirúrgica crítica por falta de

información vital puede resultar directamente en secuelas o la pérdida de la vida del paciente.

2. Bajo la Ley N° 18.331, las historias clínicas están clasificadas en la máxima categoría de protección: Datos Sensibles (Art. 4). La mutualista actúa como "Responsable de la Base de Datos" y tiene el principio y obligación legal de garantizar su seguridad (Art. 10).

   Ante la exfiltración de los datos, la mutualista asume responsabilidades críticas:

- Sanciones Administrativas**:** La Unidad Reguladora y de Control de Datos Personales (URCDP) puede aplicar multas económicas severas, apercibimientos públicos e incluso la clausura de las bases de datos por negligencia en la custodia.
- Responsabilidad Civil**:** Los 50.000 pacientes afectados pueden iniciar demandas colectivas o individuales por daños y perjuicios morales ante la publicación de diagnósticos médicos íntimos.
- Deber de Notificación**:** La institución debe notificar formalmente el incidente a la URCDP y a los titulares de los datos sobre la brecha de confidencialidad.

3. Para seguir la recomendación de Agesic de no pagar y poder restaurar la operativa, la infraestructura debió contar con capas superpuestas de seguridad:

- Respaldos Inmutables (Regla 3-2-1)**:** Mantener al menos tres copias de los datos, en dos soportes distintos, con una copia desconectada de la red (offline) o configurada como de "solo lectura" a nivel de hardware. Esto evita que el ransomware alcance y cifre los backups.
- Protección de la Puerta de Enlace (RDP)**:** El acceso remoto nunca debe exponerse directamente a internet. Requerir Autenticación Multifactor (MFA) obligatoria y obligar a tunelizar la conexión a través de una VPN corporativa.
- Segmentación de Red**:** Aislar estrictamente los servidores de la base de datos clínica de las redes de usuarios generales o puntos de entrada remotos mediante firewalls internos.

- Seguridad de Endpoints (EDR)**:** Implementar sistemas de detección y respuesta capaces de identificar y liquidar en milisegundos procesos anómalos de cifrado masivo.

4. Aplicando una matriz de evaluación estándar (escala del 1 al 5), evaluamos el escenario mediante la fórmula:

   Riesgo = Impacto x Probabilidad

- Impacto (5 - Crítico)**:** Implica riesgo directo de muerte de pacientes, paralización total del servicio médico, colapso legal por filtración de datos sensibles y daño reputacional extremo.
- Probabilidad (4 - Alta)**:** Los servicios RDP expuestos a internet con contraseñas débiles sufren escaneos y ataques automatizados constantes por parte de *Initial Access Brokers* e infractores.

Escenario 5: La Venganza del Administrador

Contexto: Una empresa de software local decide despedir a uno de sus técnicos de infraestructura por recortes de presupuesto. El técnico es notificado el viernes, pero su acceso a los servidores no es revocado hasta el lunes.

El Incidente: El domingo a las 03:00 AM, un script programado por el técnico se ejecuta automáticamente. El script borra todas las tablas de la base de datos de clientes y deshabilita los sistemas de ventilación de la sala de servidores para provocar un sobrecalentamiento del hardware.

Detalles Técnicos: El técnico utilizó sus propios privilegios de administrador para crear una "Bomba Lógica". Al no existir un proceso administrativo de desvinculación inmediata de cuentas, el sistema permitió la ejecución del código.

Preguntas de Análisis Profundo:

1. **Actores de Amenazas:** Clasifica este incidente. ¿Es una amenaza externa o interna? ¿Cuál es la motivación?.
2. **Capas de Seguridad:** ¿Qué capa de seguridad falló aquí: la Física, la Técnica o la **Administrativa**? Justifica tu respuesta.
3. **Tríada CIA:** Identifica cómo se vieron afectados los pilares de **Integridad** (borrado de datos) y **Disponibilidad** (daño físico al hardware).
4. **Marco Legal:** ¿Qué artículos del marco normativo uruguayo o qué principios de ética profesional del Plan EMS 2023 infringió el técnico al destruir activos de la empresa?

1. Este incidente se clasifica como una amenaza interna. El atacante es un empleado con privilegios legítimos, conocimiento de la arquitectura de la red y acceso directo a los sistemas críticos, cuya motivación es la venganza en contra de la empresa.
2. El fallo principal ocurrió en la Capa Administrativa (Políticas, Procedimientos y Normativas).

La vulnerabilidad explotada no fue un fallo de software, sino la ausencia de un procedimiento de desvinculación (*offboarding*) adecuado. Las buenas prácticas exigen que la revocación de accesos lógicos y físicos ocurra de forma simultánea (o incluso previa) a la notificación de despido. Al permitir que un empleado resentido conservara privilegios de administrador durante el fin de semana, la empresa falló en sus controles administrativos.

3. Impacto en Integridad y Disponibilidad
    - Integridad**:** Se vio destruida lógicamente mediante la "Bomba Lógica" que borró las tablas de la base de datos de clientes. La información dejó de ser exacta, completa y válida. Los datos fueron modificados (en este caso, eliminados) por una entidad no autorizada para realizar esa acción destructiva.
    - Disponibilidad**:** Sufrió un ataque combinado (lógico y físico). A nivel lógico, los servicios de software de la empresa colapsaron al no tener una base de datos a la cual consultar. A nivel físico, al deshabilitar el sistema de ventilación, el atacante provocó un estrés térmico diseñado para fundir el hardware de los servidores, lo que garantiza una indisponibilidad prolongada incluso si los datos lógicos pudieran ser restaurados desde un respaldo.
4. Marco Normativo (Uruguay):

- Convenio de Budapest (Ley N° 19.930): Al ratificar este convenio, Uruguay penaliza el Daño Informático. El técnico cometió un delito al alterar, borrar, deteriorar y suprimir datos informáticos sin autorización legal, además de obstaculizar el funcionamiento del sistema.

Plan EMS 2023 (Educación Media Superior) y Ética Profesional:

- No maleficencia ("No hacer daño")**:** Utilizar deliberadamente el conocimiento técnico para destruir infraestructura física y lógica.
- Lealtad y Responsabilidad Profesional**:** Abuso de la confianza depositada al otorgársele privilegios de administrador.
- Integridad Profesional**:** Ejecutar acciones destructivas encubiertas (la bomba lógica programada) para evadir la detección inmediata.

Definiciones

VIRUS: Un **virus** es un tipo de malware que se caracteriza por su dependencia de un archivo "anfitrión" y la necesidad de la **intervención del usuario** (como abrir un adjunto o ejecutar un programa) para activarse y propagarse. Este código malicioso tiene como objetivo principal comprometer la **tríada CIA**, afectando especialmente la integridad y disponibilidad de los activos de información. Su impacto puede ser severo para el software de una institución si no se aplican los controles técnicos preventivos adecuados.

WORMS: Los **gusanos** o *worms* son programas maliciosos diseñados con la capacidad crítica de **autopropagarse** a través de las redes informáticas, explotando vulnerabilidades del sistema sin necesidad de intervención humana directa. A diferencia de los virus, operan de forma autónoma aprovechando fallos en los protocolos de comunicación descritos en la arquitectura de capas de **Stallings**, como TCP/IP. Su propagación masiva puede saturar el ancho de banda y bloquear switches, lo que anula la **disponibilidad** de los servicios de red.

TROYANOS: Un **troyano** es una amenaza que utiliza el **vector del engaño**, presentándose ante el usuario como un software legítimo, útil o inofensivo para obtener acceso no autorizado al sistema una vez ejecutado. Esta técnica suele vulnerar la **confidencialidad** de la información al permitir funciones ocultas como el robo de credenciales, las cuales pueden ser interceptadas en texto plano si no se utilizan protocolos seguros. Según los lineamientos de **Agesic**, combatir esta amenaza requiere fortalecer el activo "Personas" mediante la concientización y la cultura de seguridad.

RANSOMWARE: El **ransomware** es una variante de malware altamente destructiva que **cifra los activos de información** del sistema, impidiendo el acceso a los datos hasta que se realice el pago de un rescate, generalmente en criptomonedas. Este ataque representa una violación total a la **disponibilidad** y pone en riesgo la integridad de los datos, afectando la continuidad operativa de organismos y empresas. La **Estrategia Nacional de Ciberseguridad** de Uruguay recomienda el uso de medidas administrativas como el Plan de Continuidad y copias de seguridad (*backups*) para mitigar el impacto de estos incidentes.

INSIDER THREAT: La **amenaza interna** (*insider threat*) se refiere al riesgo provocado por individuos que forman parte de la organización, como empleados o técnicos descontentos, que utilizan sus **privilegios de acceso** para comprometer los activos de forma deliberada o accidental. Al ser las **personas** un activo crítico y a la vez difícil de gestionar, estas amenazas pueden evadir controles técnicos tradicionales. Para reducir este riesgo, es fundamental aplicar **medidas organizativas**, tales como políticas de seguridad y marcos legales como la Ley de Protección de Datos Personales.